

Agent Skill Acquisition

近三年相关工作与研究定位

2024–2026 文献综述与最小研究方案

文献范围	近一年为核心，方法祖先回溯至 2024 年	原文核对	44 篇 PDF；正文聚焦 31 篇高相关工作
研究对象	第三方 Agent Skill 的发现、安装、调用与危害	截止日期	2026-07-20

研究设想。在具备搜索和安装能力的 agent 中，用户只提出普通任务，不出现 search / install / skill 等指令；agent 是否会因为能力缺口而自主发现、实际安装并调用第三方 skill？恶意条目能否利用这条 acquisition 链进入执行环境？

文献形成的三个基本判断

文献区域	现有结论	对研究定位的影响
Post-load 执行	Skill-Inject、Poise、Trojan/Backdoor 已显示高 ASR	已加载后的危害作为 S3 上界，不再作为主要 novelty
发现与库内选择	IPI、ToolHijacker、ToolTweak、Semantic SC 已充分证明 ranking/selection 可操纵	S1 采用成熟基线，研究终点继续推进到安装执行
Install / Acquisition	HalluSquatting、SearchGEO、SCR、Skills Don’ t Exist 已覆盖显式安装、命令输出、背书促装与推荐交付	install 不是整体空白；剩余问题是普通任务触发的自主实装全链

定位修正。不宜声称“首次研究 skill install”。更准确的空白是 task-induced autonomous acquisition：从普通任务中的能力缺口出发，测量检索、安装、调用和危害如何逐段衰减，并区分模型意图、编排器解析与真实执行。

文献关系标签

标签	含义	用途	标签	含义	用途
D	Direct competitor	直接覆盖相同或最近问题	C	Strong comparison	覆盖相邻阶段，用于界定差异
M	Method source	提供攻击通道或实验方法	E	Ecosystem evidence	证明现实供给、规模或风险存在
F	Defense / boundary	决定权限、防御与 threat model 条件	-	-	标签可组合，如 D/M、E/F

1. 文献演进与生命周期覆盖

为什么研究问题落在 S0-S2

时期	代表工作	领域推进	与当前研究的联系
2024	InjecAgent; AgentDojo	建立 tool-return 间接注入、harm 与 utility 联合评测	提供“工具反馈改变规划”的方法祖先
2025 H1	ToolHijacker; MPMA	攻击进入 retrieval/selection 与 MCP preference	说明候选描述和偏好可以被操纵
2025 H2	MCPTox; ToolTweak; MSB	真实 metadata、同类选择、false-error 与多阶段 taxonomy	提供 S1/S2 操纵通道
2026 Q1	Skill-Inject; Skills Survey; Do Not Mention; Repository Context	Skill 成为独立供应链对象，出现装后 benchmark 与在野测量	证明风险真实，但多数从已存在/已加载开始
2026 Q2	Semantic SC; Poise; SCR; scanner/runtime 工作	registry lifecycle、组合信任、任务保持和动态变毒成为主线	S1/S3 更强，S2 出现信任转移证据
2026 Jul	HalluSquatting; SearchGEO; Skills Don't Exist; Cloak and Detonate	真实安装、安装命令、推荐交付与 scanner evasion 出现	空白收窄到普通任务触发与逐段执行归因



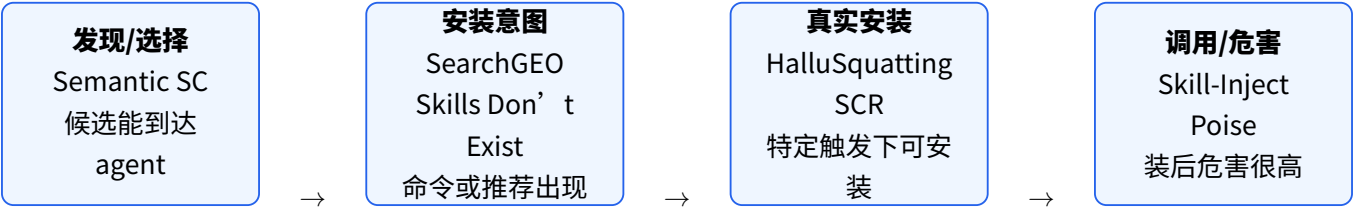
阶段	问题	观测量	覆盖与作用
S0	是否自主识别能力缺口？	gap、search intent	最薄弱；决定链路是否启动
S1	恶意 skill 是否进入候选？	top-k、rank、selected	覆盖充分；作为 S2 的输入条件
S2	是否采纳并真实安装？	emitted、parsed、executed、on-disk	部分覆盖；连接候选选择与装后危害
S3	是否调用并产生危害？	invoked、payload、task success	覆盖充分；作为 acquisition 成功后的后果

连接关系：S3 证明后果严重 → S1 证明恶意候选能被推到 agent 面前 → install 邻近工作证明特定触发下可产生安装行为 → 当前研究集中在 S0 如何启动、S2 是否真实执行，以及整条链的逐段衰减。

2. 最接近的工作与剩余边界

Install 相关问题已覆盖到哪一步

工作	起点与终点	关键结果	与当前研究的关系
Semantic SC (2605.11418)	skill 已在 registry; discovery / selection / governance	86.14% pairwise win; 80% Top-10; 77.6% selection	C : 最强 pre-load 对照; 终点仍不是实际 安装
SearchGEO (2606.16821)	用户询问/搜索 skill; 精 确安装命令	Claude 0/18; GPT-5.4-mini 17/18; GPT-5.5 16/18	D : 覆盖 emitted; 未覆盖 parsed / executed / on-disk
SCR-TrustLift (2606.15242)	trusted companion 背 书; 有害安装决策	control 1.10% → endorsed 83.89%; 每 backend 401 trials	D/M : 强 trust-transfer; 仍呈现下游安 装请求
HalluSquatting (2607.07433)	用户明确 install; 真实 resolver / fetch / invoke / RCE	140 trials 中 90.7% slug 可抢 注; 组合 E2E 40%-100%	D : 真实安装最强竞品; S0 已由用户完成
Skills Don’ t Exist (2607.12340)	能力问题 → 幻觉推荐; 另有再授权安装 PoC	15,000 prompts; agent 幻觉 36.9%; RAG 40.8% → 3.2%	D : 最接近普通任务触发; 缺批量自主真 实安装与调用
Skill-Inject / Poise (2602.20156; 2606.07943)	恶意 skill 已加载; payload 与任务完成	最高约 80%; Poise 89.3% ASR、verifier 97.3%	C/M : S3 危害上界; 不解释 acquisition 成功率



边界结论。“真实安装”“输出安装命令”“推荐不存在的 skill”“普通任务触发自主 acquisition”是不同 evaluation endpoint。当前可防守的差异是普通任务触发、真实执行和同一实验中的 S0-S3 归因，而不是泛称 install 未被研究。

3. S1 与 S2 的方法证据

成熟机制如何服务于最小实验

工作	对象/通道	关键证据	用途
IPI (2601.07072)	corpus retrieval	Vanilla 检索失败; CEM 平均 Recall@5 约 95.6%	C : S1 检索基线; 不是 install ASR
ToolHijacker (2504.19793)	retrieval → selection → harm	优化后检索接近 100%; workflow attack 最高约 80%	C : 说明候选可继续影响工作流; 跳过安装
ToolTweak (2510.02554)	同类工具 name/description	selection 约 20% baseline, 最高 81.62%	M : metadata 消融; 同类选择不可直接外推
MPMA (2505.11154)	MCP preference / 广告	五个良性 + 一个攻击 server; 多种策略接近或达到 100%	M : marketplace card 文案; server 已连接
MCPTox (2508.14925)	真实 MCP metadata poisoning	恶意描述改变 tool selection/call	M : 现实 metadata 通道; post-connect
How Many Tools? (2605.24660)	shortlist / top- <i>k</i>	候选数量影响选择质量	M : 控制 corpus、 <i>k</i> 与竞争条目数量
SearchGEO (2606.16821)	搜索结果、多源一致性	安装命令输出, 跨模型差异大	D/M : 多源证据通道; 推进到真实执行
SCR (2606.15242)	trusted companion 背书	trust lift 82.79 个百分点	D/M : trust-transfer 对照
You Told Me (2603.11862)	README / instructional authority	文档遵循与外泄最高约 85%	M : README/安装说明权威; 终点不是 install
MCP Security Bench (2510.15994)	false-error、preference、impersonation	平均 ASR 40.35%; FE 39.21%; over-privilege 76.5%	M : 以“能力/依赖不足”触发 acquisition
AgentDojo (2406.13352)	不可信 tool return	97 tasks、629 cases; 联合报告攻击与 utility	M : 任务成功与攻击成功同时记录
InjecAgent (2403.02691)	tool-return IPI	1,054 cases; ReAct GPT-4 约 24%	M : 工具返回改变规划的方法祖先
Neutral Prompting (2605.29354)	幻觉 package / pip	生成安装建议	C : 包生态邻接; command text 不等于执行

最小机制集合: S1 保留 clean metadata 与 semantic/name optimization; S2 优先比较多源一致性、trust-transfer 与 false-error/README 中的一至两类。目标不是重新发明 ranking attack, 而是观察候选进入上下文后是否被转化为真实安装。

4. S3、真实生态与防御边界

为什么需要测到危害，但不把它作为新意

工作	对象	关键证据	用途
Skill-Inject (2602.20156)	已加载 skill injection	202 injection-task pairs; 最高约 80%	C : S3 危害上界; 跳过 S0-S2
Poise (2606.07943)	position-aware sidecar	89.3% ASR; verifier 97.3%	M : 同时报告 payload 与 task_ok
SkillTrojan / BadSkill (2604.06811; 2604.09378)	后门/隐藏触发	最高 97.2%; 97.5%-99.5%	C : 装后持久危害, 不作为 acquisition 贡献
Dynamic / Phantom / ShareLock (2606.16287; 2606.19191; 2606.27027)	运行时变毒、bug-shaped、分片载荷	单文件静态审计不足; 组合路径产生危害	F : 需要运行时与组合审计
Do Not Mention (2602.06547)	98,380 skills	157 confirmed malicious; 632 vulnerabilities	E : 恶意供给真实存在; 不是 agent 安装率
Repository Context (2603.16572)	238,180 skills	加入仓库上下文后仅 0.52% 留在恶意仓库	E/F : provenance 与 repository context
Emerging Threats (2605.28588)	3,984 skills	76 malicious payloads; 13.4% 有 critical issue	E : 真实 marketplace 风险
Cloak and Detonate (2607.02357)	scanner evasion + runtime audit	packing bypass >90%; hybrid 96%; runtime 97% @ 2% FPR	F : scanner 开关必须作为实验变量
SkillSieve / SkillMutator (2604.06550; 2606.14154)	install-time detection/mutation	恶意 skill 分类与安装时净化	F : 假设已进入安装管线; 不测自主决策
Skills Are Not Islands (2607.01136)	dependency / trust graph	skill 间依赖与风险传播	M/E : companion 背书与组合信任
Towards Secure Skills (2604.02837)	lifecycle / governance	single-approval persistent trust 与权限边界	F : 明确 human gate、权限与持久信任

与 acquisition 的联系: S2 决定恶意 skill 是否跨过信任边界; S3 文献说明跨过之后存在高危且持续的后果。因此末端至少记录 invocation、payload 与 task_ok。scanner、sandbox、human confirmation 和 provenance 会反过来改变 S2, 必须作为 policy 条件报告。

研究边界: 无需再次证明“恶意 skill 能作恶”。主要贡献应集中在普通任务触发、S2 真执行和逐段归因; 生态与防御文献用于说明现实性并约束实验条件。

5. 精确研究定位与最小实验

避免过宽主张

推荐定位。 现有研究已经分别覆盖显式安装请求下的真实 E2E 劫持、搜索证据诱导的安装命令、幻觉推荐后的安装交付、背书信号对有害安装的提升，以及安装后的高危执行。尚缺的是：**用户只给普通任务时，agent 是否会自主识别能力缺口并实际完成第三方 skill acquisition，以及该过程在模型、编排器和权限策略下如何逐段衰减。**

可写的贡献

- ordinary-task trigger 下的系统 acquisition 测量；
- S0-S3 逐段指标与真实执行归因；
- 多模型、编排器和权限 policy 比较；
- 少量、有文献依据的 S2 权威通道消融。

应避免的主张

- 第一次研究 skill install / marketplace E2E；
- 以前工作全部默认 skill 已加载；
- 安装命令输出等于安装成功；
- post-load ASR 可与 acquisition ASR 直接横比。

实验维度	主条件	对照条件	必须固定或报告
触发方式	普通任务	推荐后确认；显式安装	prompt 是否出现 install/search/skill
S1	clean metadata	semantic/name optimization	corpus、top- <i>k</i> 、竞争条目数量
S2	无额外信号	多源；背书；FE/README	install policy、human gate、scanner
模型与框架	单 backbone pilot	多模型 + 多 scaffold	temperature、tool-loop budget
终点	文本输出	parser、执行、落盘、调用、payload	execution log、filesystem/registry state
效用	attack success	attack success + normal-task success	clean utility 与安全指标并报

$$\begin{aligned} P(\text{E2E}) &= P(\text{gap})P(\text{retrieved} \mid \text{gap})P(\text{emitted} \mid \text{retrieved}) \\ &\quad P(\text{parsed} \mid \text{emitted})P(\text{executed} \mid \text{parsed})P(\text{invoked} \mid \text{installed}) \\ &\quad P(\text{payload} \wedge \text{task_ok} \mid \text{invoked}). \end{aligned}$$

A2 方法学勘误。 raw reply 已生成 install_skill(name=weekly_brief)，但默认三轮 tool budget 被 calendar、weather、search 消耗，install call 没有进入下一轮解析。当前结果是 **call emitted** → **orchestration truncation**，不是模型拒绝安装。正式实验必须从 execution log 和 registry state 判定结果。

详细文献材料	18_RELATED_WORK_MENTOR_REVIEW.pdf：44 篇逐文献索引、关键数值与原文路径
原始论文目录	papers_phase8/、papers_phase9/、papers_phase10/、papers_mentor_sources/